

Reaver

Your Aircrack-ng guide closed by flagging this as a genuinely independent attack path — where Aircrack-ng's WPA2 technique depends entirely on passphrase strength and wordlist coverage, Reaver bypasses the passphrase altogether by attacking a completely separate feature: **WPS (Wi-Fi Protected Setup)**. Worth locking in the distinction immediately: **Part 1 covers exactly why WPS's PIN design is structurally weak, independent of any password choice — Part 2 covers practical Reaver usage, timing considerations, and why real-world success rates vary so much by router vendor** — since WPS lockout policies introduced specifically in response to this attack have meaningfully changed its practical reliability since Reaver was first released.

1. Why WPS's PIN Design Is Broken — The Foundation

WPS was designed as a convenience feature, letting a user connect a new device to a WPA/WPA2 network by entering a short PIN (or pressing a physical button) instead of typing the full passphrase. The PIN is 8 digits — but critically, it is **not validated as a single 8-digit unit**:

PIN Component	Validation	Search Space
Digits 1–4	Validated separately	10,000 combinations
Digits 5–7	Validated separately	1,000 combinations
Digit 8	Checksum derived from digits 1–7	No additional entropy
Total	Two-stage validation	~11,000 guesses

If the PIN were validated as one complete 8-digit value, the theoretical search space would be **100,000,000 combinations**. The two-stage validation reduces the effective search space substantially.

The single fact this entire guide is built around — because the router acknowledges the first half and second half of the PIN independently, an attacker learns whether each half is correct BEFORE needing to guess the other half, collapsing the effective search space from 100,000,000 down to roughly $10,000 + 1,000 = 11,000$ total guesses — a brute-forceable space in a practical amount of time, entirely independent of how strong the network's actual WPA/WPA2 passphrase is. Once the correct PIN is found, the router

discloses the actual passphrase directly to the requesting device as part of the normal WPS protocol flow — handing the attacker the passphrase without ever attacking it directly.

PART 1: The Vulnerability in Detail

2. The Two-Stage Validation Weakness

1. Test the first PIN portion

- The attacker submits the first four digits.
- The router responds with an indication of whether that portion is correct.

2. Test the second PIN portion

- The attacker submits the next three digits.
- The final digit is a checksum and does not require an independent guess.
- The router again provides validation feedback.

3. Recover the complete PIN

- The two validated portions can be combined to obtain the complete WPS PIN.

This early-acknowledgment behavior is the entire vulnerability — a correctly designed validation scheme would only confirm success after the FULL PIN was submitted, forcing an attacker to search the full 100,000,000-combination space; WPS's per-half acknowledgment instead lets an attacker solve two much smaller problems sequentially.

3. Why Router Vendors Responded With Lockout Policies

Given how directly exploitable this design flaw is, most router vendors have since implemented **WPS lockout** — temporarily disabling WPS entirely after a threshold of failed PIN attempts (commonly triggered after a small number of failures, locking WPS for a period of minutes to hours). This is a direct, vendor-side mitigation specifically targeting this attack, and its presence (or absence, or specific threshold/duration) varies considerably across router models and firmware versions — making Reaver's real-world reliability highly dependent on

the specific target hardware, unlike Aircrack-ng's more universally applicable techniques.

4. Pixie Dust Attack — An Offline Variant

A related but distinct technique, often implemented alongside or as an extension to Reaver, exploits weak or predictable random number generation in certain router chipsets' WPS implementation — allowing the PIN to be computed **offline** from a single captured exchange, rather than requiring thousands of live, rate-limitable online attempts against the router at all. Where applicable (dependent on the specific chipset), this bypasses lockout policies entirely, since no repeated online guessing is needed.

PART 2: Practical Usage

5. Prerequisites

Reaver requires the same **monitor mode** precondition as Aircrack-ng (see that guide's Section 2), and specifically requires identifying a target access point with WPS **enabled** — not every network has WPS active, and Reaver's technique is entirely inapplicable to networks where it's disabled.

```
wash -i wlan0mon
```

wash (part of the Reaver package) scans for and identifies nearby access points with WPS ENABLED specifically, including whether WPS is currently locked - a required reconnaissance step before attempting Reaver's PIN attack, since attempting it against a WPS-disabled or already-locked target wastes time without any chance of success

6. Running the Standard Online PIN Attack

```
reaver -i wlan0mon -b AA:BB:CC:11:22:33 -vv
```

```
-i    → monitor-mode interface  
-b    → target BSSID
```

```
-vv → verbose output, useful for observing progress and  
diagnosing lockout/rate-limiting behavior in real time
```

Reaver systematically works through the reduced ~11,000-combination search space described in Section 1, reporting progress and, upon success, the recovered WPS PIN and the underlying WPA/WPA2 passphrase directly.

7. Handling Lockout — Timing and Delay Options

```
reaver -i wlan0mon -b AA:BB:CC:11:22:33 -d 30 --lock-delay=60
```

```
-d 30 → delay (seconds) between individual PIN attempts,  
reducing the chance of triggering a target's  
lockout threshold  
--lock-delay=60 → wait time after a detected lockout before  
resuming attempts
```

Given Section 3's vendor-side mitigations, tuning these delay parameters to stay under a specific target's undisclosed lockout threshold is often the difference between a successful and an entirely unsuccessful attempt — this tuning is inherently trial-and-error per target, since lockout thresholds aren't advertised.

8. Pixie Dust Mode

```
reaver -i wlan0mon -b AA:BB:CC:11:22:33 -K 1
```

```
-K 1 → attempt the Pixie Dust offline variant (Section 4) rather  
than the standard online brute-force approach - viable  
only against specific vulnerable chipsets, but when  
applicable, dramatically faster and immune to lockout  
entirely, since it requires only a single captured  
exchange rather than thousands of live attempts
```

9. Interpreting Failure

Observation	Possible Interpretation
Consistent EAP-NACK responses with no	The target may not be vulnerable, or WPS lockout may have engaged.

progress	
Extremely slow progress	Lockout or rate limiting may be active; timing parameters may need review during an authorized assessment.
No WPS detected by <code>wash</code>	The Reaver technique is not applicable to the target; use another authorized wireless assessment method.

10. Testing Methodology

1. Confirm authorization

Verify that the specific wireless network is within the approved assessment scope.

2. Enable monitor mode

Configure the wireless interface for monitor mode, consistent with the Aircrack-ng workflow.

3. Identify WPS-enabled targets

Use `wash` to confirm that WPS is enabled and determine whether the target currently appears locked.

4. Check for Pixie Dust applicability

Where chipset compatibility is known or plausible, assess whether the offline Pixie Dust technique is applicable.

5. Assess the standard WPS PIN mechanism

If Pixie Dust is not applicable, use the standard online PIN assessment with conservative timing.

6. Evaluate lockout behavior

If WPS lockout is encountered, document the observed behavior and assess the effectiveness of the configured protection.

7. Document the result

If both assessment paths fail, record WPS as not successfully exploitable under the tested conditions and proceed with other authorized wireless security checks.

11. Legal & Ethical Note

Reaver should only be used against wireless networks for which you have **explicit authorization**.

Unauthorized attempts to recover WPS PINs, access credentials, or network passphrases may be illegal depending on the jurisdiction.

Legitimate use includes:

- Your own wireless equipment.
- An explicitly authorized penetration-testing engagement.
- A dedicated and isolated security-testing environment.
- Educational environments where permission has been granted.

Always define the assessment scope, permitted techniques, target systems, and testing window before testing begins.

12. Prevention

Primary Recommendation

- **Disable WPS whenever it is not required.**

Disabling WPS removes this attack surface entirely.

If WPS Must Remain Enabled

- **Use a robust WPS lockdown policy.**

Configure a short failed-attempt threshold and an appropriate lockdown duration where supported.

- **Keep router firmware updated.**

Firmware updates may include fixes for WPS implementation and random-number-generation weaknesses relevant to Pixie Dust attacks.

- **Do not rely on password strength alone.**

A strong WPA2/WPA3 passphrase does not eliminate a vulnerable WPS PIN attack path because WPS is a separate authentication feature.

- **Migrate to WPA3 where practical.**

WPA3 improves the underlying wireless security protocol, but WPS should still be evaluated separately and disabled where it is unnecessary.

13. Quick Reference Cheat Sheet

Discover WPS-Enabled Targets

```
wash -i wlan0mon
```

Standard Online PIN Assessment

```
reaver -i wlan0mon -b <target> -vv
```

Lockout-Aware Timing

```
reaver -i wlan0mon -b <target> -d 30 --lock-delay=60
```

Pixie Dust Assessment

```
reaver -i wlan0mon -b <target> -K 1
```

Key Takeaways

- WPS PIN validation separates the PIN into independently validated portions.
- This reduces the effective search space compared with treating the PIN as one complete 8-digit value.
- WPS security is therefore an independent assessment area from the strength of the underlying WPA/WPA2/WPA3 passphrase.
- Vendor lockout and rate-limiting controls can significantly affect the practicality of online PIN attacks.
- WPS status should be checked separately even when the underlying wireless passphrase is strong.